

Security issues with pickles #2522

Open

KOLANICH opened on Mar 27, 2020 · edited by KOLANICH

Edits ⌵ ⋮

Pickles security nightmare because they allow arbitrary code execution and because this code is not explicitly visible, to extract and analyse it tools are needed that currently don't exist. They are good places to plant hardly discovered backdoors. But this lib relies heavily on them. It downloads some pickled pretrained stuff and doesn't work without it.

We need to solve this issue. There are several issues here:

1. Pickles are used. They should be replaced. The replacements can be some custom code and either a feature-specific binary format, or general purpose binary format, such as CBOR.
2. I haven't found the recipes to build the pretrained models. I mean for each pretrained model should be
 - a python file that:
 - fetches the needed datasets
 - preprocesses the data and trains the model
 - evaluating its performance
 - intentionally written the way to be easily auditable
 - and a JSON config file storing
 - hyperparams
 - datasets locations
 - previously achieved performance

So, if using project- or thirdparty devs-provided pickles is unacceptable because I cannot trust them, I should be able to recreate own pickles from scratch. Anyway, even if we replace pickles by something else, we still need the way to improve the pretrained models, i.e. by retraining them on better datasets or using better hyperparams (I have a lib for hyperparams tuning, BTW). So, IMHO for every pretrained model there should be the code reproducing its creation.



 **Dunedan** mentioned this [on Jun 21, 2024](#)

✓ [Remote code execution vulnerability in NLTK #3266](#)



 **ekaf** mentioned this [on Dec 15, 2025](#)

🕒 [Unsafe pickle loading in a few modules #3486](#)

Assignees

No one assigned

Labels

No labels

Type

No type

Projects

No projects

Milestone

No milestone

Relationships

None yet

Development

 Code with agent mode

▼

No branches or pull requests

Participants

